

Gruppenaufgabe 4

Einführung in Ransomware

Szenario

Die «FinSecure AG», eine Finanzberatungsfirma mit 80 Mitarbeitenden in Luzern, wurde am vergangenen Wochenende Opfer eines Ransomware-Angriffs. Sämtliche Kundendaten, Finanzdokumente und E-Mail-Server sind verschlüsselt. Die Angreifer fordern 50 Bitcoins Lösegeld innerhalb von 72 Stunden. Als IT-Sicherheitsberater sollen Sie den Vorfall analysieren, die Anforderungen an eine ransomware-sichere Datensicherung ableiten und einen Notfallplan entwerfen.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Den typischen Ablauf eines Ransomware-Angriffs analysieren und die einzelnen Phasen einer konkreten Situation zuordnen.
- Spezifische Anforderungen an eine ransomware-resistente Datensicherung ableiten und begründen.
- Einen praxistauglichen Notfallplan für den Fall eines Ransomware-Angriffs entwickeln und strukturieren.

Arbeitsauftrag

Erarbeiten Sie in Ihrer Kleingruppe eine Analyse des Ransomware-Vorfalles bei der «FinSecure AG». Rekonstruieren Sie den wahrscheinlichen Angriffsablauf, leiten Sie daraus mindestens fünf Anforderungen an eine sichere Backup-Strategie ab und erstellen Sie einen Notfallplan mit konkreten Sofortmassnahmen, Kommunikationswegen und Wiederherstellungsschritten.

Ergebnis

Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie den rekonstruierten Angriffsablauf, Ihre Top-5-Anforderungen an die Datensicherung und den Notfallplan mit den drei wichtigsten Sofortmassnahmen vorstellen.

Musterlösung A | Gruppenaufgabe 4 | Einführung in Ransomware

Ansatz: Strukturiert-analytisch

1. Rekonstruktion des Angriffsablaufs

Basierend auf dem beschriebenen Szenario und typischen Ransomware-Angriffsmustern lässt sich folgender wahrscheinlicher Ablauf rekonstruieren:

Phase	Zeitpunkt	Beschreibung
1. Erstinfektion	Ca. 2–4 Wochen vor dem Angriff	Ein Mitarbeitender öffnete eine Phishing-E-Mail mit einem schädlichen Anhang (z. B. eine präparierte Excel-Datei mit Makros). Der Anhang installierte unbemerkt einen Trojaner auf dem Arbeitsplatzrechner.
2. Auskundschaftung	1–3 Wochen vor dem Angriff	Die Angreifer nutzten den Trojaner, um das interne Netzwerk zu scannen. Sie identifizierten Domain-Controller, Dateiserver, E-Mail-Server und – kritisch – die Backup-Infrastruktur.
3. Rechteerhöhung	1–2 Wochen vor dem Angriff	Durch Ausnutzung einer ungepatchten Schwachstelle im Active Directory erlangten die Angreifer Domain-Admin-Rechte. Damit hatten sie vollen Zugriff auf alle Systeme.
4. Backup-Sabotage	1–3 Tage vor dem Angriff	Die Angreifer löschten oder verschlüsselten die vorhandenen Backup-Daten auf dem Backup-Server, der im selben Netzwerksegment wie die Produktivsysteme stand.
5. Verschlüsselung	Samstagnacht	Am Wochenende, als keine IT-Mitarbeitenden anwesend waren, starteten die Angreifer die Verschlüsselung aller identifizierten Systeme.
6. Lösegeldforderung	Sonntagmorgen	Auf allen Bildschirmen erschien die Lösegeldforderung: 50 Bitcoins innerhalb von 72 Stunden.

2. Schwachstellenanalyse

Die Analyse des Angriffsablaufs offenbart folgende zentrale Schwachstellen:

1. **Fehlende E-Mail-Sicherheit:** Die Phishing-E-Mail wurde nicht erkannt und blockiert.
2. **Ungepatchte Systeme:** Eine bekannte Schwachstelle im Active Directory ermöglichte die Rechteerhöhung.
3. **Keine Netzwerksegmentierung:** Backup-Server und Produktivsysteme befanden sich im selben Netzwerk.
4. **Kein Offline-Backup:** Alle Backups waren online und damit für die Angreifer erreichbar und zerstörbar.
5. **Kein Monitoring am Wochenende:** Die Verschlüsselung lief stundenlang unentdeckt, weil kein IT-Personal die Systeme überwachte.

3. Top-5-Anforderungen an eine ransomware-sichere Datensicherung

Nr.	Anforderung	Begründung
A1	Offline-Backup (Air-Gap)	Mindestens eine Backup-Kopie muss physisch vom Netzwerk getrennt sein, sodass Ransomware keinen Zugriff darauf hat. Dies ist die letzte Verteidigungslinie.
A2	Immutable Storage	Backup-Daten dürfen für einen definierten Zeitraum nicht verändert oder gelöscht werden können – auch nicht mit Admin-Rechten. Moderne Backup-Lösungen bieten WORM-Funktionalität (Write Once Read Many).
A3	3-2-1-Regel	Mindestens drei Kopien der Daten auf zwei verschiedenen Medientypen, davon eine ausser Haus. Diese Regel stellt sicher, dass selbst bei Kompromittierung eines Standorts Daten verfügbar bleiben.
A4	Tägliche Backup-Überwachung mit Alarmierung	Jeder fehlgeschlagene Backup-Job muss sofort eine Alarmmeldung an den verantwortlichen IT-Mitarbeitenden auslösen.
A5	Monatliche Restore-Tests	Regelmässige Wiederherstellungstests stellen sicher, dass Backups tatsächlich funktionsfähig sind und die Wiederherstellungszeit bekannt ist.

4. Notfallplan für Ransomware-Angriffe

Phase 1: Sofortmassnahmen (erste 60 Minuten)

Schritt	Massnahme	Verantwortlich
---------	-----------	----------------

1	Alle betroffenen Systeme sofort vom Netzwerk trennen (Netzwerkkabel ziehen, WLAN deaktivieren)	IT-Leiter
2	Geschäftsleitung und IT-Sicherheitsbeauftragten informieren	IT-Leiter
3	Externen IT-Forensik-Dienstleister kontaktieren	Geschäftsleitung
4	Ausmass des Angriffs feststellen: Welche Systeme sind betroffen? Sind Backups intakt?	IT-Team
5	Polizei und NCSC (Nationales Zentrum für Cybersicherheit) informieren	Geschäftsleitung

Phase 2: Kommunikation (erste 24 Stunden)

Zielgruppe	Massnahme
Mitarbeitende	Informieren, dass keine Systeme genutzt werden dürfen, bis Entwarnung gegeben wird
Kunden	Proaktive Information über mögliche Verzögerungen, ohne unnötige Panik
FINMA	Als Finanzdienstleister ist eine Meldung an die Finanzmarktaufsicht zu prüfen
Versicherung	Cyberversicherung (falls vorhanden) sofort informieren und Schadenfall melden

Phase 3: Wiederherstellung (Tag 2–7)

1. Forensische Analyse: Angriffsvektor identifizieren und Schwachstelle schliessen.
2. Saubere Neuinstallation aller betroffenen Systeme von verifizierten Installationsmedien.
3. Wiederherstellung der Daten aus dem letzten verifizierten, intakten Backup.
4. Schrittweise Wiederinbetriebnahme: Zuerst kritische Systeme, dann sekundäre.
5. Verstärkte Überwachung aller Systeme für mindestens 30 Tage nach Wiederherstellung.

5. Empfehlung zur Lösegeldforderung

Die Empfehlung lautet klar: Kein Lösegeld bezahlen. Erstens gibt es keine Garantie, dass die Angreifer den Schlüssel liefern. Zweitens finanziert jede Zahlung weitere Angriffe.

Drittens empfehlen sowohl das NCSC als auch die Strafverfolgungsbehörden ausdrücklich, nicht zu bezahlen. Stattdessen sollte die Wiederherstellung aus Backups priorisiert werden – vorausgesetzt, intakte Offline-Backups existieren.

6. Fazit

Der Angriff auf die FinSecure AG zeigt exemplarisch, wie Ransomware-Gruppen vorgehen: geduldig, systematisch und mit dem Ziel, alle Rettungsmöglichkeiten zu eliminieren. Die fünf abgeleiteten Anforderungen an die Datensicherung – insbesondere Offline-Backup und Immutable Storage – sind keine optionalen Verbesserungen, sondern zwingende Voraussetzungen für eine ransomware-resistente IT-Infrastruktur.

Musterlösung B | Gruppenaufgabe 4 | Einführung in Ransomware

Ansatz: Praxisnah-narrativ

1. Der Montagmorgen bei der FinSecure AG

Es ist Montagmorgen, 7:15 Uhr. Die erste Mitarbeiterin der FinSecure AG schaltet ihren Computer ein. Statt des gewohnten Login-Bildschirms erscheint eine Nachricht auf rotem Hintergrund: «Your files have been encrypted. Pay 50 BTC within 72 hours or your data will be published.» Sie ruft den IT-Leiter an. Dieser eilt ins Büro und stellt fest: Jeder einzelne Computer, der E-Mail-Server, der Dateiserver und – der schlimmste Fund – auch der Backup-Server zeigen dieselbe Meldung. Die FinSecure AG ist komplett lahmgelegt.

2. Wie ist das passiert? Die Rekonstruktion

Um zu verstehen, wie es dazu kommen konnte, müssen wir einige Wochen zurückblicken. Alles begann wahrscheinlich mit einer einzigen E-Mail. Ein Mitarbeitender erhielt eine täuschend echt aussehende Nachricht, angeblich von der Schweizer Post – mit einem Anhang namens «Sendungsverfolgung.xlsm». Er öffnete die Datei, aktivierte die Makros, und damit war die Tür offen.

Was dann passierte, merkte niemand. Die Schadsoftware arbeitete leise im Hintergrund. Sie scannte das Netzwerk, fand den Domain-Controller und nutzte eine bekannte, aber nicht gepatchte Schwachstelle aus, um sich Administratorenrechte zu verschaffen. Mit diesen Rechten kartografierten die Angreifer das gesamte Netzwerk: Dateiserver, E-Mail-Server, Datenbanken – und eben auch den Backup-Server.

Dann warteten sie auf den perfekten Moment: Samstagabend, 23:00 Uhr. Kein IT-Personal im Haus. Keine Überwachung. Die Angreifer starteten zuerst die Löschung der Backup-Daten – denn sie wissen genau, dass ein Unternehmen mit funktionierendem Backup kein Lösegeld bezahlt. Erst danach begann die Verschlüsselung aller Produktivsysteme. Um 3:00

Uhr morgens war alles verschlüsselt. Um 7:15 Uhr entdeckte die erste Mitarbeiterin das Desaster.

3. Was die FinSecure AG falsch gemacht hat

Lassen Sie uns ehrlich sein: Die FinSecure AG hat gleich mehrere Grundregeln der IT-Sicherheit missachtet. Das ist kein Vorwurf – es ist Realität in vielen KMU. Aber es hilft zu verstehen, was anders hätte sein müssen:

Fehler 1: Kein Offline-Backup. Der Backup-Server hing im selben Netzwerk wie alle anderen Systeme. Für die Angreifer war er genauso erreichbar wie der Dateiserver. Ein Offline-Backup – eine externe Festplatte im Tresor, ein Band im Safe, eine Cloud-Kopie mit separaten Zugangsdaten – hätte die Rettung sein können.

Fehler 2: Kein Patch-Management. Die Schwachstelle im Active Directory, die den Angreifern die Rechteerhöhung ermöglichte, war seit Monaten bekannt. Ein Patch stand zur Verfügung. Er wurde nie eingespielt.

Fehler 3: Keine Netzwerksegmentierung. Alles war mit allem verbunden. Der Arbeitsplatz des Mitarbeitenden, der die Phishing-Mail öffnete, hatte Netzwerkzugriff auf den Backup-Server. Das darf nicht sein.

Fehler 4: Keine Awareness-Schulung. Der Mitarbeitende, der die Phishing-Mail öffnete, tat dies nicht aus Nachlässigkeit, sondern aus Unwissenheit. Er wusste nicht, woran man eine Phishing-Mail erkennt. Eine einzige Schulung pro Jahr hätte dieses Risiko deutlich reduziert.

Fehler 5: Kein Wochenend-Monitoring. Die Angreifer wählten bewusst das Wochenende. Ein automatisiertes Monitoring-System, das bei ungewöhnlichen Aktivitäten (z. B. massenhafte Dateiverschlüsselung) Alarm schlägt, hätte den Angriff möglicherweise frühzeitig stoppen können.

4. Was jetzt zu tun ist: Der Notfallplan

In der akuten Krise muss die FinSecure AG drei Dinge sofort tun:

Sofortmassnahme 1: Netzwerk trennen – JETZT. Alle Netzwerkkabel ziehen. Alle WLAN-Access-Points abschalten. Das Ziel: Die Ausbreitung stoppen, falls die Verschlüsselung noch läuft oder die Angreifer noch im Netzwerk aktiv sind.

Sofortmassnahme 2: Hilfe holen. Die FinSecure AG braucht jetzt professionelle Unterstützung: einen IT-Forensik-Dienstleister, der den Angriff analysiert und bei der Wiederherstellung hilft. Gleichzeitig muss die Polizei informiert werden und das NCSC (Nationales Zentrum für Cybersicherheit). Als Finanzdienstleister ist zudem zu prüfen, ob eine Meldung an die FINMA erforderlich ist.

Sofortmassnahme 3: Nicht bezahlen. Die Versuchung ist gross – 50 Bitcoins für die Rettung aller Daten. Aber: Es gibt keine Garantie, dass die Angreifer den Schlüssel liefern. In vielen Fällen funktioniert die Entschlüsselung nicht vollständig. Ausserdem finanziert jede

Zahlung die nächsten Angriffe. Das NCSC, die Polizei und alle seriösen IT-Sicherheitsexperten raten einhellig: Nicht bezahlen.

5. Die fünf Lehren für die Zukunft

Was muss die FinSecure AG ändern, damit so etwas nie wieder passiert?

1. **Offline-Backup einführen:** Eine Backup-Kopie, die physisch vom Netzwerk getrennt ist. Das kann ein Wechselmedium sein, das täglich in den Tresor gelegt wird, oder ein Immutable Storage in der Cloud, der auch mit Admin-Rechten nicht löscher ist.
2. **Netzwerk segmentieren:** Backup-Infrastruktur muss in einem eigenen, isolierten Netzwerksegment stehen. Der Zugriff erfolgt nur über dedizierte, gehärtete Verbindungen.
3. **Mitarbeitende schulen:** Vierteljährliche Awareness-Schulungen mit simulierten Phishing-Mails. Das Ziel: Jeder Mitarbeitende erkennt eine verdächtige E-Mail und weiss, was zu tun ist.
4. **Patch-Management automatisieren:** Sicherheitsupdates müssen zeitnah und automatisiert eingespielt werden. Ein Patch, der drei Monate auf dem Schreibtisch liegt, schützt niemanden.
5. **Ransomware-Notfallplan erstellen und üben:** Der Notfallplan muss schriftlich vorliegen, allen Beteiligten bekannt sein und mindestens einmal jährlich in einer Übung getestet werden. Denn im Ernstfall zählt jede Minute, und wer erst dann überlegt, was zu tun ist, verliert wertvolle Zeit.

6. Die Botschaft an die Geschäftsleitung

Die Kernbotschaft an die Geschäftsleitung der FinSecure AG lautet: Ransomware ist kein theoretisches Risiko – es ist Realität. Der Angriff hat gezeigt, dass die bisherige Sicherheitsarchitektur nicht ausreicht. Die gute Nachricht: Die fünf beschriebenen Massnahmen sind konkret, umsetzbar und bezahlbar. Die Kosten für ihre Implementierung betragen einen Bruchteil des Schadens, den dieser Angriff verursacht hat.

Die Frage ist nicht, ob ein weiterer Angriff kommt. Die Frage ist, ob die FinSecure AG dann besser vorbereitet sein wird.

</content>

</document>

Beide Dateien stehen nun als separate Canvas-Dokumente zum Herunterladen bereit:

Datei	Inhalt	Format
Unit1_Inhaltsfolien.md	Agenda, 24 Inhaltsfolien (4 × 6), Zusammenfassung	Markdown
Unit1_Gruppenaufgaben_Musterloesungen.md	4 Gruppenaufgaben, 8 Musterlösungen (4 × A + B)	Markdown